

April 4, 2024

Recording of personal data on a letter, at a point where it was clearly visible outside the envelope

DECISION

Based on the duties and powers conferred upon me by Article 57(1)(f) of Regulation (EU) 2016/679 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data (hereinafter, "GDPR"), I have examined a complaint submitted to my Office on 10/11/2023, against the Social Insurance Services, regarding the recording of personal data on a letter, at a point where it was clearly visible outside the envelope.

Following the investigation of the complaint, I have found a violation of the GDPR by the Social Insurance Services and, therefore, I issue this Decision.

1. Facts of the Case

1.1. On 10/11/2023, a complaint was submitted to my Office by Mr. XXXX (hereinafter, "the Complainant"), against the Social Insurance Services (hereinafter, "the Respondents").

1.2. According to the Complainant, he had requested from the Respondents, at the address veveosisnic@sid.mlsi.gov.cy, to send him the detailed statement of his earnings. The Respondents sent the earnings statement to the Complainant approximately two weeks later.

1.3. However, as the Complainant stated, his personal data, namely the identity card number (ID number) and the social insurance number (SSN), were recorded on the part of the letter where the recipient is indicated and were clearly visible outside the postal envelope. The Complainant asserts that access to this data was available to everyone who handled the envelope (e.g., postman, postal service), which constitutes unlawful processing of his personal data.

1.4. On 08/12/2023, I notified the Respondents of the content of the submitted complaint and requested their positions regarding the Complainant's allegations, as well as the purpose of recording the ID number and SSN at the point where the recipient is indicated, resulting in the data being clearly visible to third parties.

1.5. On 12/02/2024, I sent a polite reminder to the Respondents, as the deadline I had initially set for receiving their response had passed.

1.6. In their reply letter, the Respondents informed me that instructions had been sent to all provincial offices of the Respondents to make the necessary corrections to the letters so that the ID number and SSN would not be visible outside the postal envelope. To support their positions, the Respondents shared the email they sent to the provincial offices.

2. Legal Aspect

The following are the Articles and Recitals of the GDPR, which constitute the legal basis for the complaint in question:

2.1. Article 4 of the GDPR

"1) 'personal data': any information relating to an identified or identifiable natural person ('data subject'); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier such as a name, an identification number, location data, an online identifier, or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural, or social identity of that natural person;

2) 'processing': any operation or set of operations which is performed on personal data or on sets of personal data, whether or not by automated means, such as collection, recording, organization, structuring, storage, adaptation or alteration, retrieval, consultation, use, disclosure by transmission, dissemination or otherwise making available, alignment or combination, restriction, erasure or

destruction;

7) 'data controller': the natural or legal person, public authority, agency, or other body which, alone or jointly with others, determines the purposes and means of the processing of personal data; where the purposes and means of such processing are determined by Union law or the law of a Member State, the data controller or the specific criteria for its designation may be provided for by Union law or the law of a Member State."

2.2. Article 32 of the GDPR

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the data controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk [...].

2. In assessing the appropriate level of security, account shall be taken in particular of the risks that are presented by processing, in particular from accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to personal data."

character that was transmitted, stored, or otherwise processed».

2.3. Article 58 of the GDPR

"1. Each supervisory authority shall have all of the following investigative powers:

a) to order the controller and the processor and, where applicable, the representative of the controller or the processor to provide any information it requires for the performance of its tasks,

b) to conduct investigations in the form of audits to ensure compliance with data protection,

d) to notify the controller or the processor of an alleged infringement of this Regulation,

e) to obtain from the controller and the processor access to all personal data and all information necessary for the performance of its tasks,

f) to have access to the premises of the controller and the processor, including any equipment and means used for processing data, in accordance with the procedural law of the Union or of a Member State.

2. Each supervisory authority shall have all of the following corrective powers: [...]

b) to issue warnings to the controller or the processor when processing operations have infringed provisions of this Regulation".

3. Reasoning

3.1. Firstly, the respondents to the complaint act as the controller for the personal data they maintain, disclose, and, in general, process.

3.2. According to Article 32 of the GDPR, taking into account, among other things, the risks arising from a processing operation they undertake, as well as the likelihood of their occurrence and the severity for the rights and freedoms of data subjects, the respondents to the complaint, as the controller, have an obligation to implement appropriate technical and organizational measures to ensure an appropriate level of security against those risks.

3.3. In assessing the appropriate level of security, the respondents to the complaint must primarily take into account risks such as, among others, the unauthorized disclosure or access to personal data being processed.

3.4. In this case, the respondents to the complaint act as the controller for the personal data of the complainant, as referred to in the complaint, namely their ID numbers and tax identification numbers, since they maintain the said data for their own purposes and determined the manner and means of sending the relevant data to the complainant.

3.5. Therefore, based on Article 32 of the GDPR, the respondents to the complaint were obliged to

take sufficient and appropriate measures to ensure that, when sending the data to the complainant, the personal data of the latter would enjoy an appropriate level of security against the risks that might arise.

3.6. The ID numbers and tax identification numbers were written in a part of the letter from which they could be viewed, apart from the postal envelope, by third parties. In fact, when the respondents to the complaint were asked about the purpose of including the said data in that specific part of the letter, they responded that they took actions to ensure that this data would no longer be written in a location easily visible to third parties.

3.7. Taking into account both the positions of the complainant and those of the respondents to the complaint, I find that the inclusion of the ID numbers and tax identification numbers in a location from which they are clearly visible externally from the envelope, by third parties – other than the complainant and the respondents to the complaint – is not necessary, as it does not serve the intended purpose, namely the delivery of the letter to the correct recipient. On the contrary, it raises the risk of unauthorized access to this data.

3.8. Based on the evidence presented before me, it is not proven / apparent that third, unauthorized persons have gained access to the personal data of the complainant.

3.9. However, in any case, the respondents to the complaint should have implemented appropriate measures to ensure that the personal data included in the letter sent to the complainant would not be subject to unauthorized access. However, the respondents to the complaint did not take the necessary measures to eliminate and/or mitigate this risk, in violation of Article 32 of the GDPR.

3.10. The actions taken by the respondents to the complaint and the measures they subsequently implemented, so that the ID numbers and tax identification numbers would no longer be visible in a location clearly visible externally from the envelope when sending letters, are positively noted.

4. Conclusion

4.1 Taking into account all the above elements, as presented, and based on the powers conferred upon me by Article 58 of the GDPR, I find that there is a violation of Article 32 of the GDPR.

4.2 In light of the following mitigating (a-c) and aggravating (d) factors:

- α. the fact that no other complaint has been submitted to our Office against the Respondents regarding a similar incident,
- β. the subsequent measures taken by the Respondents so that the viewing of the ID numbers and other personal data is no longer possible externally from the file during the sending of letters,
- γ. the fact that it is not proven that third parties have gained access to the personal data of the Complainant,
- δ. the absence of appropriate technical and organizational measures by the Respondents,

exercising the corrective powers conferred upon me by Article 58(2) of the GDPR, pursuant to which "Each supervisory authority shall have all of the following corrective powers: [...]

b) to issue warnings to the controller or the processor when processing operations have infringed provisions of this Regulation."

4.3 I have decided to issue a Warning to the Social Insurance Services for the violation of Article 32 of the GDPR.

Eirini Loizidou Nicolaidou
Commissioner for Personal Data Protection